

RELATÓRIO DE AUDITORIA

Segurança e Conformidade RGPD

Notely

Confidencial

Uso interno - não distribuir sem autorização

Data	01 de setembro de 2026
Versão da auditoria	V2 do prompt de auditoria (teste mock)
Nome do projeto	Notely
Escopo	Aplicação SaaS de notas e espaços colaborativos - backend Express/Prisma, frontend Next.js, deploy Docker/Terraform (AWS eu-west-1).

Nota metodológica

Categorias 1-3 (isolamento, permissão no navegador, IDOR) foram mapeadas ao RBAC custom e às queries Prisma: cada rota de listagem/leitura/escrita foi confrontada com o escopo do usuário autenticado. A categoria 4 foi verificada com scans no histórico git (gitleaks), docker-compose, IaC e bundle do frontend. A categoria 5 varreu template de UI (v-html/dangerouslySetInnerHTML) e e-mail transacional. A categoria de RGPD foi aplicada ao inventário de dados da Fase 0 e aos fluxos de consentimento, exclusão, cookies e retenção. Toda severidade considerou o contexto (dados sensíveis Art. 9, volume de usuários).

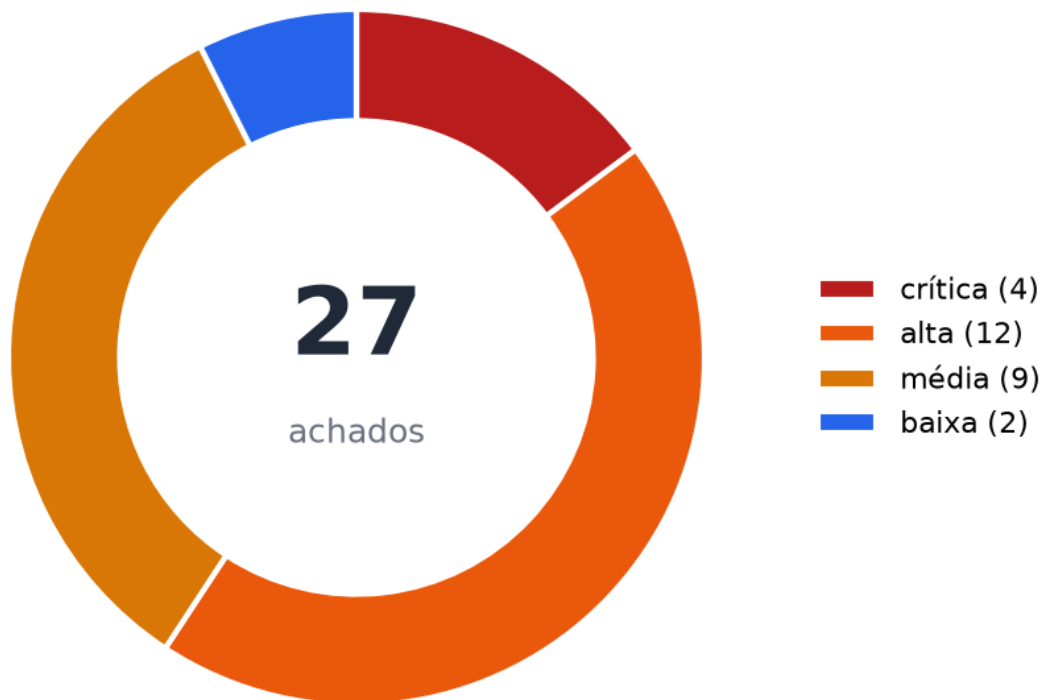
Mapa da stack detectada (Fase 0)

Camada	Deteccção
Backend	TypeScript 5.3 / Node.js 18 LTS / Express 4.18
ORM / DB	Prisma 5.6 (PostgreSQL 15)
Autenticação	JWT RS256 (JWKS) + RBAC custom (roles: admin, member)
Frontend	Next.js 13.4 (App Router) + React 18 + Tailwind
Sanitização	DOMPurify presente no package.json, NÃO aplicado
Deploy / IaC	Docker + docker-compose + Terraform (AWS eu-west-1) + GitHub Actions
Dados pessoais	PII: email, nome, notas, activity log, health form (Art. 9), telemetria
Terceiros	PostHog (analytics), Sentry (crash), Resend (e-mail), Cloudflare (CDN)

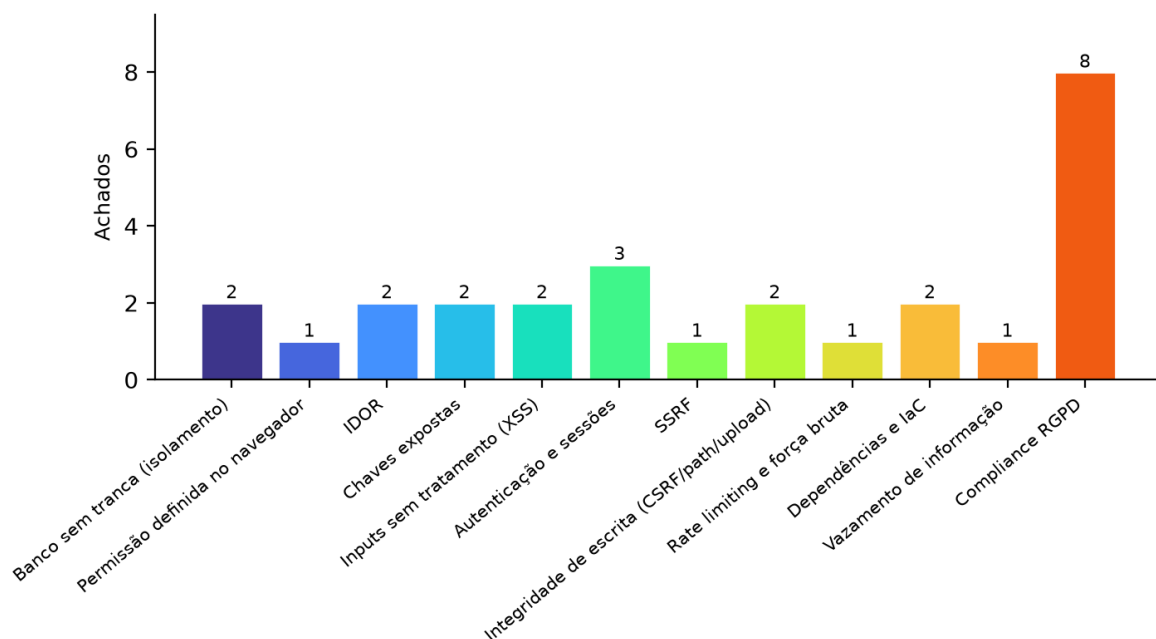
Resumo executivo

Foram identificados **27** achados: **4** críticos, **12** altos, **9** médios e **2** baixos. Os riscos centrais estão em isolamento de dados (tenant), autorização no servidor, gestão de credenciais e conformidade RGPD.

Distribuição por severidade



Distribuição por categoria



Contagem resumida

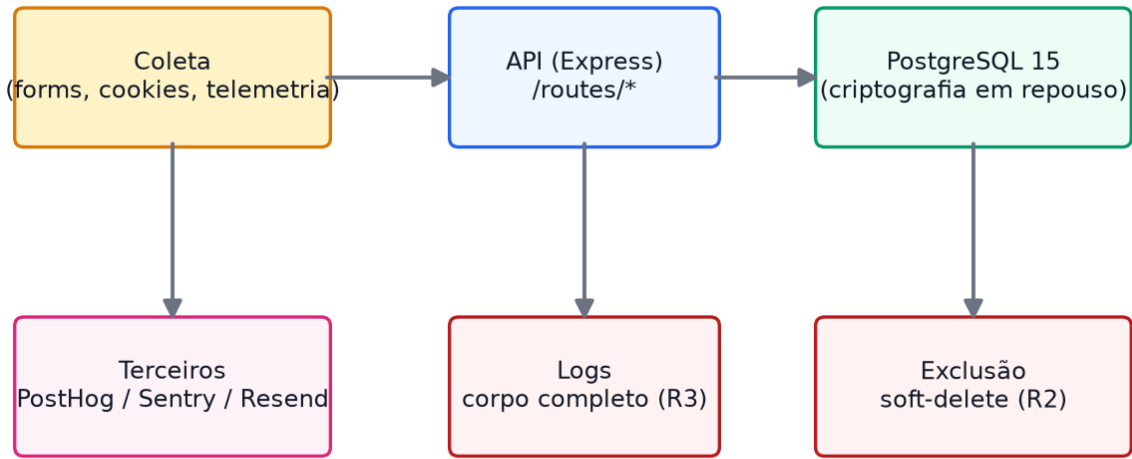
Severidade	Total
Crítica	4
Alta	12
Média	9
Baixa	2
Informativa	0

Painel de conformidade RGPD

Status por obrigação verificado contra o código real (Fase 0 + categoria de compliance). 'Não verificada' significa ausência de evidência no repositório, não ausência de risco.

Sub-check	Obrigação	Status	Evidência
12.1	Base legal e consentimento (Art. 6, 7)	não conformidade	SignupForm.tsx:12
12.2	Cookies e rastreamento (ePrivacy)	não conformidade	analytics.ts:5
12.3	Direitos dos titulares (Art. 15-22)	não conformidade	users.ts:77
12.4	Minimização e retenção (Art. 5(1)(c),(e))	não conformidade	logger.ts:9 / expunge.ts:1
12.5	Segurança e pseudonimização (Art. 32)	em conformidade	TLS 1.2+, KMS em repouso
12.6	Transferências internacionais (Art. 44-49)	em conformidade	eu-west-1 + SCC
12.7	Processadores e terceiros (Art. 28)	não verificada	Sem DPA com Resend
12.8	Notificação de violação (Art. 33-34)	em conformidade	runbook.md
12.9	Privacidade por design e DPIA (Art. 25, 35)	em conformidade	Perfis privados por padrão
12.10	Política de privacidade (Art. 12-13)	não conformidade	privacy/page.tsx:3
12.11	Menores (Art. 8)	não aplicável	B2B
12.12	PII em locais indevidos	não verificada	Bundle não rastreado
12.13	Dados sensíveis (Art. 9)	não conformidade	HealthForm.tsx:7
12.14	Decisão automatizada e perfilagem (Art. 22)	não conformidade	score.ts:22
12.15	Trilha de auditoria de acesso a PII	não conformidade	lib/audit.ts vazio
12.16	Canais não-code de exercício de direitos	em conformidade	privacidade@notely.app + SLA 30d

Fluxo de dados pessoais (Art. 30)



Retenção: sem job de expurgo (R5) - fluxo de dados pessoais (Fase 0 / RGPD Art. 30)

Pontos fortes (verificados)

apps/api/src/middleware/auth.ts:14 - Middleware de autenticação valida assinatura RS256, expiração e emissor (JWKS) e é aplicado em todas as rotas sob /api.

Nota: Categoria 2/3: a autenticação em si está correta; o problema são as rotas que a ignoram.

apps/web/src/lib/session.ts:22 - Cookies de sessão com HttpOnly, Secure e SameSite=Lax.

Nota: Mitiga roubo de sessão por XSS (parcialmente, até a categoria 5 ser corrigida).

apps/api/src/routes/notes.ts:21 - Inputs de criação de nota validados com schema zod (tamanho e tipo).

Nota: Categoria 5: reduz a superfície de injeção estrutural.

apps/api/src/middleware/team.ts:31 - GET /api/teams/:id valida pertencimento do chamador ao time.

Nota: Categoria 3: padrão correto a ser replicado nos sub-recursos.

terraform/main.tf:41 - Volumes de banco criados com encryption_at_rest habilitado (AWS KMS).

Nota: RGPD Art. 32: criptografia em repouso dos dados pessoais.

docs/incidentes/runbook.md - Runbook de resposta a incidente com notificação à autoridade em até 72h e registro de violações.

Nota: RGPD Art. 33-34: processo documentado.

Pontos fracos (riscos centrais)

- Isolamento e posse fragilizados: rotas de listagem/exclusão/exportação operam sem escopo de tenant ou dono (F1, F2, F4, F5).
- Autorização frágil: papel validado apenas na UI e não no servidor em ações privilegiadas (F3).
- Gestão de credenciais precária: senhas SHA-256, secrets com default público e chave real no histórico git (F6, F7, F10).
- Conformidade RGPD incompleta: consentimento inválido, exclusão soft-only, rastreamento sem opt-in e retenção indefinida (R1-R5).

Achados detalhados por categoria

Listados arquivo por arquivo, linha por linha.

Categoria 1 - Banco sem tranca (isolamento)

ID	Severidade	Arquivo:linha	Descrição	CWE
F1	crítica	apps/api/src/routes/notes.ts:42	Listagem de notas não filtra por spaceId/usuário: devolve todas as notas de todos os espaços.	CWE-639
F2	alta	apps/api/src/routes/team.ts:88	Exportação CSV de atividade agrega registros de todos os tenants sem WHERE por inquilino.	CWE-639

F1 - crítica - apps/api/src/routes/notes.ts:42 - CWE-639

```
const notes = await prisma.note.findMany({}); // sem filtro de tenant
```

Por que é explorável: Qualquer usuário autenticado lista notas de outros inquilinos ao chamar GET /api/notes.

Impacto: Exposição transversal de dados (cross-tenant) de todos os clientes.

Correção: Injetar scope obrigatório: prisma.note.findMany({ where: { spaceId: session.spaceId } }).

F2 - alta - apps/api/src/routes/team.ts:88 - CWE-639

```
SELECT * FROM activity WHERE space_id = ANY(...) // agrega todos
```

Por que é explorável: O endpoint /api/teams/export recebe ?spaceIds= e não valida pertencimento de cada id.

Impacto: Exfiltração de dados de atividade (PII) de outras organizações.

Correção: Validar pertencimento de cada spaceId antes de agregar; adicionar filtro de tenant no SQL.

Categoria 2 - Permissão definida no navegador

ID	Severidade	Arquivo:linha	Descrição	CWE
F3	crítica	apps/web/src/pages/settings/TeamSettings.tsx:15	O botão de excluir time fica escondido para não-admins na UI, mas DELETE /api/teams/:id não valida papel.	CWE-862

F3 - crítica - apps/web/src/pages/settings/TeamSettings.tsx:15 - CWE-862

```
{isAdmin && <DeleteTeamButton/>} // gate apenas na UI
```

Por que é explorável: apps/api/src/routes/team.ts:120 registra router.delete('/:id', auth, handler) sem requireRole('admin').

Impacto: Qualquer membro pode excluir/alterar configurações do time (escrita privilegiada).

Correção: Adicionar middleware de autorização requireRole('admin') em todas as mutações de team.

Categoria 3 - IDOR

ID	Severidade	Arquivo:linha	Descrição	CWE
F4	crítica	apps/api/src/routes/notes.ts:66	Exclusão de nota por ID sem verificar se a nota pertence ao usuário/space do chamador.	CWE-639
F5	alta	apps/api/src/routes/team.ts:55	Lista de membros de um time sem validar que o chamador pertence ao time.	CWE-639

F4 - crítica - apps/api/src/routes/notes.ts:66 - CWE-639

```
router.delete('/:id', auth, async (req, res) => { await prisma.note.delete({ where: { id } }); });
```

Por que é explorável: Não há where: { ownerId } nem verificação de posse antes do delete.

Impacto: Deleção/IDOR: qualquer usuário apaga recursos de qualquer outro usuário.

Correção: Buscar nota com ownerId do token; 404/403 se não pertencer; excluir com where composto.

F5 - alta - apps/api/src/routes/team.ts:55 - CWE-639

```
router.get('/:teamId/members', auth, async (req, res) => { ... });
```

Por que é explorável: apps/api/src/middleware/team.ts valida posse apenas em GET /api/teams/:id, não no sub-recurso members.

Impacto: Vazamento de PII (nomes/e-mails de membros) de times privados de outras empresas.

Correção: Aplicar middleware de membership no sub-recurso /:teamId/* com verificação de posse.

Categoria 4 - Chaves expostas

ID	Severidade	Arquivo:linha	Descrição	CWE
F6	alta	docker-compose.yml:12	Segredo de assinatura JWT com default público e sem validação de startup que rejeite o default.	CWE-798
F7	alta	apps/api/.env (git history, commit a1b2c3d):1	Chave real de produção commitada em .env e removida depois; ainda acessível no git history.	CWE-798

F6 - alta - docker-compose.yml:12 - CWE-798

```
JWT_SECRET=${JWT_SECRET:-dev-secret-notely} # default publico
```

Por que é explorável: Se JWT_SECRET não for injetado, produção assina tokens com 'dev-secret-notely' conhecido.

Impacto: Forjar tokens JWT e acessar qualquer conta com papel admin.

Correção: Remover default; falhar no boot se a env não existir; usar secrets manager.

F7 - alta - apps/api/.env (git history, commit a1b2c3d):1 - CWE-798

```
STRIPE_API_KEY=sk_live_51N3x... // removida do HEAD mas presente no histórico
```

Por que é explorável: gitleaks localizou a chave no commit a1b2c3d; quem tiver acesso ao repo pode extraí-la.

Impacto: Fraude/comprometimento de pagamentos; chave precisa ser rotacionada.

Correção: Rotacionar chave; purgar histórico (filter-repo); adicionar gitleaks no pre-commit e CI.

Categoria 5 - Inputs sem tratamento (XSS)

ID	Severidade	Arquivo:linha	Descrição	CWE
F8	alta	apps/web/src/components/NoteContent.tsx:9	Conteúdo de nota (HTML do usuário) renderizado sem sanitização apesar de DOMPurify estar no package.json.	CWE-79
F9	média	apps/api/src/services/mailer.ts:31	Nome do usuário interpolado em e-mail HTML sem escape/escape.	CWE-80

F8 - alta - apps/web/src/components/NoteContent.tsx:9 - CWE-79

```
<div dangerouslySetInnerHTML={{ __html: note.content }} /> // sem DOMPurify
```

Por que é explorável: Outro usuário pode criar nota com .

Impacto: XSS persistente entre usuários (roubo de sessão, execução no contexto admin).

Correção: Sanitizar com DOMPurify no client e com lib equivalente no servidor antes de persistir.

F9 - média - apps/api/src/services/mailer.ts:31 - CWE-80

```
`<p>Olá, ${user.name}</p>` // interpolação sem escape
```

Por que é explorável: Nome controlado por usuário com </script> quebra o template e pode virar phishing/XSS no cliente de e-mail.

Impacto: Phishing direcionado e injeção em template de e-mail.

Correção: Escape de HTML ou uso de template engine com autoescape para campos do usuário.

Categoria 6 - Autenticação e sessões

ID	Severidade	Arquivo:linha	Descrição	CWE
F10	crítica	apps/api/src/lib/password.ts:8	Senhas armazenadas com SHA-256 simples, sem salt e sem algoritmo de derivação lento.	CWE-916
F11	média	apps/api/src/routes/auth.ts:40	Login de administradores sem exigência de segundo fator.	CWE-287
F12	alta	apps/api/src/routes/auth.ts:120	Token de reset de senha numérico de 6 dígitos sem tentativa de limite/rate limit.	CWE-640

F10 - crítica - apps/api/src/lib/password.ts:8 - CWE-916

```
crypto.createHash('sha256').update(pw).digest('hex') // hash sem sal e rapido
```

Por que é explorável: Banco vazado permite brute-force offline imediato de senhas (sem custo computacional).

Impacto: Comprometimento em massa de contas com senhas recuperáveis.

Correção: Migrar para argon2id/bcrypt com salt por usuário; rehash em login.

F11 - média - apps/api/src/routes/auth.ts:40 - CWE-287

```
router.post('/login', loginHandler) // sem MFA/2FA
```

Por que é explorável: Credenciais vazadas (F6/F10) bastam para acesso admin; não há TOTP/WebAuthn.

Impacto: Account takeover de administradores com impacto total no produto.

Correção: Exigir MFA para funções privilegiadas (admin, suporte) e eventos sensíveis.

F12 - alta - apps/api/src/routes/auth.ts:120 - CWE-640

```
token = Math.floor(100000 + Math.random()*900000) // 6 dígitos, 5 min
```

Por que é explorável: Espaço de 1e6 combinações; força bruta online (categoria 9) viabiliza takeover.

Impacto: Account takeover via reset de senha.

Correção: Token aleatório de alta entropia, expiração, invalidação pós-uso e limitação de tentativas.

Categoria 7 - SSRF

ID	Severidade	Arquivo:linha	Descrição	CWE
F13	alta	apps/api/src/services/import.ts:33	URL de usuário buscada pelo servidor (preview de link) sem allowlist/denylist de hosts, sem bloqueio de IP interno e seguindo redirects.	CWE-918

F13 - alta - apps/api/src/services/import.ts:33 - CWE-918

```
const resp = await fetch(userUrl); // preview de link, sem allowlist
```

Por que é explorável: SSRF: URL pode apontar para 169.254.169.254 (metadata AWS) ou serviços internos; resposta pode ser refletida ao usuário.

Impacto: Acesso ao metadata da nuvem e a serviços internos; exfiltração via resposta.

Correção: Allowlist de domínios, bloqueio de IPs internos/link-local, proibição de redirects, timeout e validação de protocolo.

Categoria 8 - Integridade de escrita (CSRF/path/upload)

ID	Severidade	Arquivo:linha	Descrição	CWE
F14	média	apps/api/src/routes/webhook.ts:19	Cookies de API com SameSite=None e mutações sem token CSRF nem verificação de Origin.	CWE-352
F15	alta	apps/api/src/routes/import.ts:60	Nome de arquivo enviado pelo usuário interpolado no caminho sem normalização nem validação de conteúdo.	CWE-22

F14 - média - apps/api/src/routes/webhook.ts:19 - CWE-352

```
app.use(cors({ origin: true, credentials: true })) // cookies SameSite=None
```

Por que é explorável: Sites maliciosos podem disparar mutações cross-origin com credenciais do usuário (CSRF).

Impacto: Ações não autorizadas em nome do usuário (CSRF).

Correção: Restringir CORS a origem confiável, SameSite=Lax/Strict e validar Origin/CSRF token em mutações.

F15 - alta - apps/api/src/routes/import.ts:60 - CWE-22

```
const dest = path.join(UPLOAD_DIR, file.originalname);
```

Por que é explorável: originalname pode conter ../ e sobrescrever arquivos arbitrários (path traversal / zip-slip).

Impacto: Escrita arbitrária no servidor; potencial RCE via configuração sobrescrita.

Correção: Gerar nome aleatório, validar tipo por conteúdo (sniffing), limite de tamanho e armazenar fora da raiz pública.

Categoria 9 - Rate limiting e força bruta

ID	Severidade	Arquivo:linha	Descrição	CWE
F16	alta	apps/api/src/routes/auth.ts:12	Endpoints de login/reset sem rate limiting no código (depende de nginx com limite fixo não documentado).	CWE-307

F16 - alta - apps/api/src/routes/auth.ts:12 - CWE-307

```
router.post('/login', loginHandler) // sem rate limit no app
```

Por que é explorável: A categoria 12 (token de reset) é brutável e credenciais podem ser testadas em massa.

Impacto: Brute force e credential stuffing contra contas.

Correção: Rate limit por IP e por conta com backoff exponencial; lockout temporário.

Categoria 10 - Dependências e IaC

ID	Severidade	Arquivo:linha	Descrição	CWE
F17	média	package.json:45	Dependência com CVE alcançável e imagem base sem pin, ambas além da política de EOL.	CWE-1035
F18	alta	terraform/main.tf:22	Bucket S3 de exportações criado com ACL pública.	CWE-269

F17 - média - package.json:45 - CWE-1035

```
"next": "13.4.19" // CVE-2023-44487 (HTTP/2 DoS); Dockerfile: FROM node:18 (latest)
```

Por que é explorável: next@13.4.19 possui CVE conhecida; FROM node:18 sem tag específica instala versões imprevisíveis.

Impacto: DoS e builds não reproduzíveis com superfície de vulnerabilidades desconhecida.

Correção: Atualizar dependências, pin de imagem base com digest, habilitar Dependabot/CI de auditoria.

F18 - alta - terraform/main.tf:22 - CWE-269

```
acl = "public-read" # bucket de exportacoes
```

Por que é explorável: Exportações contêm PII (relatório CSV, categoria 1) e ficam legíveis publicamente.

Impacto: Vazamento público de dados de clientes.

Correção: Remover ACL pública, usar private + bucket policy restrita, verificar com checkov no CI.

Categoria 11 - Vazamento de informação

ID	Severidade	Arquivo:linha	Descrição	CWE
F19	média	apps/api/src/app.ts:10	Stack trace completo em respostas de erro em produção e ausência de headers de segurança (CSP, HSTS).	CWE-209

F19 - média - apps/api/src/app.ts:10 - CWE-209

```
app.use((err, req, res, next) => res.status(500).json({ error: err.stack })) // + sem helmet
```

Por que é explorável: Detalhes internos e versões auxiliam atacantes; sem CSP o XSS da categoria 5 amplifica.

Impacto: Reconhecimento facilitado e mitigação de XSS prejudicada.

Correção: Erros genéricos em produção, helmet/secureHeaders com CSP e HSTS.

Categoria 12 - Compliance RGPD

ID	Severidade	Arquivo:linha	Descrição	CWE
R1	média	apps/web/src/components/forms/SignupForm.tsx:12	Checkbox de marketing pré-marcada e sem registro de consentimento (timestamp, versão, finalidade).	CWE-359
R2	alta	apps/api/src/routes/users.ts:77	'Excluir conta' só marca deletedAt: notas, activity, backups e logs continuam armazenando dados pessoais.	CWE-359
R3	média	apps/api/src/middleware/logger.ts:9	Logs registram corpo completo de requisições contendo e-mail/CPF, sem expiração.	CWE-212
R4	média	apps/web/src/lib/analytics.ts:5	Script de analytics (PostHog) carregado na primeira página sem banner/consentimento prévio.	CWE-359
R5	baixa	apps/api/src/lib/expunge.ts:1	Política de retenção documentada, mas nenhum job de expurgo/expiração implementado.	CWE-212
R6	baixa	apps/web/src/app/privacy/page.tsx:3	Política de privacidade desatualizada e contradiz o que o código realmente faz (terceiros reais).	CWE-359
R7	alta	apps/web/src/components/forms/HealthForm.tsx:7	Coleta de dados sensíveis (saúde) como dado comum, sem consentimento explícito nem finalidade específica.	CWE-359
R8	média	apps/api/src/services/score.ts:22	Pontuação de crédito/risco gerada por modelo sem fluxo de intervenção humana, explicação ou revisão.	CWE-359

R1 - média - apps/web/src/components/forms/SignupForm.tsx:12 - CWE-359 - Art. 7

```
<input type="checkbox" checked={true} /> Marketing
```

Por que é explorável: RGPD Art. 7 exige opt-in explícito, não pré-marcado, e registro auditável do consentimento.

Impacto: Base legal de marketing inválida; risco de sanção (até 4% do faturamento global).

Correção: Opt-in desmarcado por padrão; persistir consentimento (quem, quando, versão, finalidade) e fluxo de retirada.

R2 - alta - apps/api/src/routes/users.ts:77 - CWE-359 - Art. 17

```
user.deletedAt = new Date(); // soft-delete apenas; notas/activity/backups ficam
```

Por que é explorável: RGPD Art. 17 exige apagamento efetivo; soft-delete não atende ao direito ao esquecimento.

Impacto: Direito de apagamento inaplicável; dados permanecem sob controle do controlador sem base.

Correção: Apagar/anonimizar dados em cascata (tabelas, cache, logs, backups) ou anonimização irreversível.

R3 - média - apps/api/src/middleware/logger.ts:9 - CWE-212 - Art. 5

```
logger.info('request', req.body) // loga e-mail e corpo inteiro
```

Por que é explorável: Minimização (Art. 5(1)(c)) e retenção (Art. 5(1)(e)) violadas; logs são coleta desnecessária.

Impacto: Retenção de PII sem prazo; aumento de superfície em caso de vazamento de logs.

Correção: Logar apenas metadados (id, rota, status), mascarar PII e aplicar retenção automática.

R4 - média - apps/web/src/lib/analytics.ts:5 - CWE-359 - Art. 7

```
posthog.init('phc_xxx', { load: () => track_all() }) // carrega antes do consentimento
```

Por que é explorável: Cookies não essenciais não podem ser instalados antes de consentimento (ePrivacy/Art. 7).

Impacto: Rastreamento sem base legal; multa por cookies não consentidos.

Correção: Banner de cookies com gestão de preferências; carregar trackers apenas após opt-in.

R5 - baixa - apps/api/src/lib/expunge.ts:1 - CWE-212 - Art. 5

```
// TODO: job de expurgo nao implementado
```

Por que é explorável: Art. 5(1)(e): dados não podem ser mantidos indefinidamente sem prazo.

Impacto: Acúmulo de dados além do necessário; risco incremental.

Correção: Implementar job agendado de expurgo por idade e categoria, com métricas e alerta.

R6 - baixa - apps/web/src/app/privacy/page.tsx:3 - CWE-359 - Art. 12-13

```
'Nao compartilhamos dados com terceiros' // contradiz PostHog/Sentry/Resend
```

Por que é explorável: Art. 12-13 exigem informação precisa; inconsistência gera risco de enforcement e dano reputacional.

Impacto: Informação enganosa ao titular; sanção por transparência.

Correção: Revisar política com inventário real de dados, finalidades, terceiros e direitos.

R7 - alta - apps/web/src/components/forms/HealthForm.tsx:7 - CWE-359 - Art. 9

```
// coleta condicoes de saude sem base legal especifica (Art. 9)
```

Por que é explorável: Art. 9 proíbe tratamento de categorias especiais sem base própria; falha gera multa máxima.

Impacto: Tratamento ilícito de dados sensíveis; alto risco a direitos fundamentais.

Correção: Consentimento explícito e destacado, minimização, DPIA e armazenamento com proteção adicional.

R8 - média - apps/api/src/services/score.ts:22 - CWE-359 - Art. 22

```
score = model.predict(features(user)) // decisao automatizada sem revisao humana
```

Por que é explorável: Art. 22: decisão automatizada com efeitos significativos exige direito à intervenção humana e explicação.

Impacto: Titulares sem recurso efetivo contra decisões automatizadas.

Correção: Prever endpoint de revisão humana, explicação e contestação da decisão.

Recomendações priorizadas

P1 - Fechar IDOR/isolamento e RBAC no servidor (F1-F5); migrar senhas para argon2id (F10); remover defaults de secrets e rotacionar chaves (F6, F7).

Corrige 4 críticas e reduz escalada total.

P2 - Sanitizar XSS (F8, F9); endurecer SSRF (F13) e uploads (F15); rate limit em login/reset (F12, F16); corrigir IaC público (F18).

Corta as altas alcançáveis em escrita e autenticação.

P3 - MFA para admin (F11), CSRF/Origin (F14), headers de segurança (F19), upgrades de dependências (F17).

Fortalece defesa em profundidade.

P4 - Adequação RGPD: consentimento e cookies (R1, R4), exclusão real (R2), minimização/retensão (R3, R5), política de privacidade (R6), dados sensíveis Art. 9 (R7), revisão humana Art. 22 (R8) e trilha de auditoria (12.15).

Fecha o plano de conformidade.

Issues para o GitHub

Para cada achado acionável, o texto completo de uma issue em Markdown, pronto para copiar e colar. Achados triviais relacionados foram agrupados em uma issue única (ex.: consentimento + cookies).

```
--- ISSUE 1 ---

## [Privacidade/RGPD] Checkbox de marketing pré-marcada e sem registro de consentimento (timestamp, versão, finalidade).

**Labels sugeridas:** `security, severidade/média, privacy`

**Descrição do problema**
Checkbox de marketing pré-marcada e sem registro de consentimento (timestamp, versão, finalidade).

**Por que é explorável:** RGPD Art. 7 exige opt-in explícito, não pré-marcado, e registro auditável do consentimento.

**Evidência**
- `apps/web/src/components/forms/SignupForm.tsx:12`
...
<input type="checkbox" checked={true} /> Marketing
...

**Impacto:** Base legal de marketing inválida; risco de sanção (até 4% do faturamento global).

**Sugestão de correção:** Opt-in desmarcado por padrão; persistir consentimento (quem, quando, versão, finalidade) e fluxo de retirada.

**Critérios de aceite**
- [ ] Checkbox desmarcada por padrão
- [ ] Tabela consent_log populada ao salvar

## [Privacidade/RGPD] Script de analytics (PostHog) carregado na primeira página sem banner/consentimento prévio.

**Labels sugeridas:** `security, severidade/média, privacy`

**Descrição do problema**
Script de analytics (PostHog) carregado na primeira página sem banner/consentimento prévio.

**Por que é explorável:** Cookies não essenciais não podem ser instalados antes de consentimento (ePrivacy/Art. 7).

**Evidência**
- `apps/web/src/lib/analytics.ts:5`
...
posthog.init('phc_xxx', { load: () => track_all() }) // carrega antes do consentimento
...

**Impacto:** Rastreamento sem base legal; multa por cookies não consentidos.

**Sugestão de correção:** Banner de cookies com gestão de preferências; carregar trackers apenas após opt-in.

**Critérios de aceite**
- [ ] Analytics não inicia sem consentimento
- [ ] Preferência de cookies persistida e reutilizada

--- FIM ISSUE 1 ---

--- ISSUE 2 ---

## [Privacidade/RGPD] Logs registram corpo completo de requisições contendo e-mail/CPF, sem expiração.

**Labels sugeridas:** `security, severidade/média, privacy`

**Descrição do problema**
Logs registram corpo completo de requisições contendo e-mail/CPF, sem expiração.

**Por que é explorável:** Minimização (Art. 5(1)(c)) e retenção (Art. 5(1)(e)) violadas; logs são coleta desnecessária.

**Evidência**
- `apps/api/src/middleware/logger.ts:9`
...
logger.info('request', req.body) // loga e-mail e corpo inteiro
...

**Impacto:** Retenção de PII sem prazo; aumento de superfície em caso de vazamento de logs.

**Sugestão de correção:** Logar apenas metadados (id, rota, status), mascarar PII e aplicar retenção automática.

**Critérios de aceite**
- [ ] Log não contém corpo da requisição
- [ ] Rotação de logs com TTL configurada

## [Privacidade/RGPD] Política de retenção documentada, mas nenhum job de expurgo/expiração implementado.

**Labels sugeridas:** `security, severidade/baixa, privacy`

**Descrição do problema**
Política de retenção documentada, mas nenhum job de expurgo/expiração implementado.
```

```
**Por que é explorável:** Art. 5(1)(e): dados não podem ser mantidos indefinidamente sem prazo.

**Evidência**
- `apps/api/src/lib/expunge.ts:1`
...
// TODO: job de expurgo nao implementado
...

**Impacto:** Acúmulo de dados além do necessário; risco incremental.

**Sugestão de correção:** Implementar job agendado de expurgo por idade e categoria, com métricas e alerta.

**Critérios de aceite**
- [ ] Job executa em staging e apaga registros vencidos
- [ ] Retenção configurável por categoria

--- FIM ISSUE 2 ---

--- ISSUE 3 ---

## [Segurança] Listagem de notas não filtra por spaceId/usuário

**Labels sugeridas:** `security, severidade/crítica`

**Descrição do problema**
Listagem de notas não filtra por spaceId/usuário: devolve todas as notas de todos os espaços.

**Por que é explorável:** Qualquer usuário autenticado lista notas de outros inquilinos ao chamar GET /api/notes.

**Evidência**
- `apps/api/src/routes/notes.ts:42`
...
const notes = await prisma.note.findMany({}); // sem filtro de tenant
...

**Impacto:** Exposição transversal de dados (cross-tenant) de todos os clientes.

**Sugestão de correção:** Injetar scope obrigatório: prisma.note.findMany({ where: { spaceId: session.spaceId } }).

**Critérios de aceite**
- [ ] GET /api/notes retorna 0 notas de outros spaces
- [ ] Teste com 2 contas em spaces distintos

--- FIM ISSUE 3 ---

--- ISSUE 4 ---

## [Segurança] Exportação CSV de atividade agrega registros de todos os tenants sem WHERE por inquilino.

**Labels sugeridas:** `security, severidade/alta`

**Descrição do problema**
Exportação CSV de atividade agrega registros de todos os tenants sem WHERE por inquilino.

**Por que é explorável:** O endpoint /api/teams/export recebe ?spaceIds= e não valida pertencimento de cada id.

**Evidência**
- `apps/api/src/routes/team.ts:88`
...
SELECT * FROM activity WHERE space_id = ANY(...) // agrega todos
...

**Impacto:** Exfiltração de dados de atividade (PII) de outras organizações.

**Sugestão de correção:** Validar pertencimento de cada spaceId antes de agregar; adicionar filtro de tenant no SQL.

**Critérios de aceite**
- [ ] Export contendo espaço de outro tenant retorna erro
- [ ] Query SQL final tem WHERE tenant_id

--- FIM ISSUE 4 ---

--- ISSUE 5 ---

## [Segurança] O botão de excluir time fica escondido para não-admins na UI, mas DELETE /api/teams/

**Labels sugeridas:** `security, severidade/crítica`

**Descrição do problema**
O botão de excluir time fica escondido para não-admins na UI, mas DELETE /api/teams/:id não valida papel.

**Por que é explorável:** apps/api/src/routes/team.ts:120 registra router.delete('/:id', auth, handler) sem requireRole('admin').

**Evidência**
- `apps/web/src/pages/settings/TeamSettings.tsx:15`
```

```
...
{isAdmin && <DeleteTeamButton/>} // gate apenas na UI
...

**Impacto:** Qualquer membro pode excluir/alterar configurações do time (escrita privilegiada).

**Sugestão de correção:** Adicionar middleware de autorização requireRole('admin') em todas as mutações de team.

**Critérios de aceite**
- [ ] DELETE sem papel admin retorna 403
- [ ] Teste automatizado cobre rota com role member

--- FIM ISSUE 5 ---

--- ISSUE 6 ---

## [Segurança] Exclusão de nota por ID sem verificar se a nota pertence ao usuário/space do chamador.

**Labels sugeridas:** `security, severidade/crítica`

**Descrição do problema**
Exclusão de nota por ID sem verificar se a nota pertence ao usuário/space do chamador.

**Por que é explorável:** Não há where:{ ownerId } nem verificação de posse antes do delete.

**Evidência**
- `apps/api/src/routes/notes.ts:66`
...
router.delete('/:id', auth, async (req, res) => { await prisma.note.delete({ where: { id } }); });
...

**Impacto:** Deleção/IDOR: qualquer usuário apaga recursos de qualquer outro usuário.

**Sugestão de correção:** Buscar nota com ownerId do token; 404/403 se não pertencer; excluir com where composto.

**Critérios de aceite**
- [ ] Deletar nota alheia retorna 404
- [ ] Notas de outros users permanecem no banco

--- FIM ISSUE 6 ---

--- ISSUE 7 ---

## [Segurança] Lista de membros de um time sem validar que o chamador pertence ao time.

**Labels sugeridas:** `security, severidade/alta`

**Descrição do problema**
Lista de membros de um time sem validar que o chamador pertence ao time.

**Por que é explorável:** apps/api/src/middleware/team.ts valida posse apenas em GET /api/teams/:id, não no sub-recurso members.

**Evidência**
- `apps/api/src/routes/team.ts:55`
...
router.get('/:teamId/members', auth, async (req, res) => { ... });
...

**Impacto:** Vazamento de PII (nomes/e-mails de membros) de times privados de outras empresas.

**Sugestão de correção:** Aplicar middleware de membership no sub-recurso /:teamId/* com verificação de posse.

**Critérios de aceite**
- [ ] GET members de time alheio retorna 403
- [ ] Middleware aplicado a todas as rotas /:teamId/*

--- FIM ISSUE 7 ---

--- ISSUE 8 ---

## [Segurança] Segredo de assinatura JWT com default público e sem validação de startup que rejeite o default.

**Labels sugeridas:** `security, severidade/alta`

**Descrição do problema**
Segredo de assinatura JWT com default público e sem validação de startup que rejeite o default.

**Por que é explorável:** Se JWT_SECRET não for injetado, produção assina tokens com 'dev-secret-notely' conhecido.

**Evidência**
- `docker-compose.yml:12`
...
JWT_SECRET=${JWT_SECRET:-dev-secret-notely} # default publico
...
```



```
**Impacto:** Forjar tokens JWT e acessar qualquer conta com papel admin.

**Sugestão de correção:** Remover default; falhar no boot se a env não existir; usar secrets manager.

**Critérios de aceite**
- [ ] Boot falha sem JWT_SECRET
- [ ] gitleaks não encontra o default no repo

--- FIM ISSUE 8 ---

--- ISSUE 9 ---

## [Segurança] Chave real de produção commitada em .env e removida depois; ainda acessível no git history.

**Labels sugeridas:** `security, severidade/alta`

**Descrição do problema**
Chave real de produção commitada em .env e removida depois; ainda acessível no git history.

**Por que é explorável:** gitleaks localizou a chave no commit a1b2c3d; quem tiver acesso ao repo pode extraí-la.

**Evidência**
- `apps/api/.env (git history, commit a1b2c3d):1`
...
STRIPE_API_KEY=sk_live_51N3x... // removida do HEAD mas presente no histórico
...

**Impacto:** Fraude/comprometimento de pagamentos; chave precisa ser rotacionada.

**Sugestão de correção:** Rotacionar chave; purgar histórico (filter-repo); adicionar gitleaks no pre-commit e CI.

**Critérios de aceite**
- [ ] Chave revogada na Stripe
- [ ] gitleaks limpo no reflog/histórico filtrado

--- FIM ISSUE 9 ---

--- ISSUE 10 ---

## [Segurança] Conteúdo de nota (HTML do usuário) renderizado sem sanitização apesar de DOMPurify estar no package.json.

**Labels sugeridas:** `security, severidade/alta`

**Descrição do problema**
Conteúdo de nota (HTML do usuário) renderizado sem sanitização apesar de DOMPurify estar no package.json.

**Por que é explorável:** Outro usuário pode criar nota com <img src=x onerror=alert(document.cookie)>.

**Evidência**
- `apps/web/src/components/NoteContent.tsx:9`
...
<div dangerouslySetInnerHTML={{ __html: note.content }} /> // sem DOMPurify
...

**Impacto:** XSS persistente entre usuários (roubo de sessão, execução no contexto admin).

**Sugestão de correção:** Sanitizar com DOMPurify no client e com lib equivalente no servidor antes de persistir.

**Critérios de aceite**
- [ ] Payload XSS não renderiza script
- [ ] DOMPurify aplicado ao render

--- FIM ISSUE 10 ---

--- ISSUE 11 ---

## [Segurança] Nome do usuário interpolado em e-mail HTML sem escape/espiação.

**Labels sugeridas:** `security, severidade/média`

**Descrição do problema**
Nome do usuário interpolado em e-mail HTML sem escape/espiação.

**Por que é explorável:** Nome controlado por usuário com <b>/<script> quebra o template e pode virar phishing/XSS no cliente de e-mail.

**Evidência**
- `apps/api/src/services/mailer.ts:31`
...
`<p>Olá, ${user.name}</p>` // interpolação sem escape
...

**Impacto:** Phishing direcionado e injeção em template de e-mail.

**Sugestão de correção:** Escape de HTML ou uso de template engine com autoescape para campos do usuário.
```

```
**Critérios de aceite**
- [ ] Nome com <script> é exibido literalmente
- [ ] Teste unitário do template

--- FIM ISSUE 11 ---

--- ISSUE 12 ---

## [Segurança] Senhas armazenadas com SHA-256 simples, sem salt e sem algoritmo de derivação lento.

**Labels sugeridas:** `security, severidade/crítica`

**Descrição do problema**
Senhas armazenadas com SHA-256 simples, sem salt e sem algoritmo de derivação lento.

**Por que é explorável:** Banco vazado permite brute-force offline imediato de senhas (sem custo computacional).

**Evidência**
- `apps/api/src/lib/password.ts:8`
...
crypto.createHash('sha256').update(pw).digest('hex') // hash sem sal e rapido
...

**Impacto:** Comprometimento em massa de contas com senhas recuperáveis.

**Sugestão de correção:** Migrar para argon2id/bcrypt com salt por usuário; rehash em login.

**Critérios de aceite**
- [ ] Nenhuma senha SHA-256 em repouso
- [ ] Migração backfill executada e verificada

--- FIM ISSUE 12 ---

--- ISSUE 13 ---

## [Segurança] Login de administradores sem exigência de segundo fator.

**Labels sugeridas:** `security, severidade/média`

**Descrição do problema**
Login de administradores sem exigência de segundo fator.

**Por que é explorável:** Credenciais vazadas (F6/F10) bastam para acesso admin; não há TOTP/WebAuthn.

**Evidência**
- `apps/api/src/routes/auth.ts:40`
...
router.post('/login', loginHandler) // sem MFA/2FA
...

**Impacto:** Account takeover de administradores com impacto total no produto.

**Sugestão de correção:** Exigir MFA para funções privilegiadas (admin, suporte) e eventos sensíveis.

**Critérios de aceite**
- [ ] Admin sem 2FA não acessa área administrativa
- [ ] Configuração de MFA documentada

--- FIM ISSUE 13 ---

--- ISSUE 14 ---

## [Segurança] Token de reset de senha numérico de 6 dígitos sem tentativa de limite/rate limit.

**Labels sugeridas:** `security, severidade/alta`

**Descrição do problema**
Token de reset de senha numérico de 6 dígitos sem tentativa de limite/rate limit.

**Por que é explorável:** Espaço de 1e6 combinações; força bruta online (categoria 9) viabiliza takeover.

**Evidência**
- `apps/api/src/routes/auth.ts:120`
...
token = Math.floor(100000 + Math.random()*900000) // 6 dígitos, 5 min
...

**Impacto:** Account takeover via reset de senha.

**Sugestão de correção:** Token aleatório de alta entropia, expiração, invalidação pós-uso e limitação de tentativas.

**Critérios de aceite**
- [ ] Reset com token errado bloqueia após 5 tentativas
- [ ] Token é UUID/256 bits

--- FIM ISSUE 14 ---
```

--- ISSUE 15 ---

[Segurança] URL de usuário buscada pelo servidor (preview de link) sem allowlist/denylist de hosts, sem bloqueio de IP interno e seguindo redirects.

Labels sugeridas: `security, severidade/alta`

Descrição do problema
URL de usuário buscada pelo servidor (preview de link) sem allowlist/denylist de hosts, sem bloqueio de IP interno e seguindo redirects.

Por que é explorável: SSRF: URL pode apontar para 169.254.169.254 (metadata AWS) ou serviços internos; resposta pode ser refletida ao usuário.

Evidência
- `apps/api/src/services/import.ts:33`
...
const resp = await fetch(userUrl); // preview de link, sem allowlist
...`

Impacto: Acesso ao metadata da nuvem e a serviços internos; exfiltração via resposta.

Sugestão de correção: Allowlist de domínios, bloqueio de IPs internos/link-local, proibição de redirects, timeout e validação de protocolo.

Critérios de aceite
- [] URL para 169.254.169.254 bloqueada
- [] Redirect a IP interno bloqueado

--- FIM ISSUE 15 ---

--- ISSUE 16 ---

[Segurança] Cookies de API com SameSite=None e mutações sem token CSRF nem verificação de Origin.

Labels sugeridas: `security, severidade/média`

Descrição do problema
Cookies de API com SameSite=None e mutações sem token CSRF nem verificação de Origin.

Por que é explorável: Sites maliciosos podem disparar mutações cross-origin com credenciais do usuário (CSRF).

Evidência
- `apps/api/src/routes/webhook.ts:19`
...
app.use(cors({ origin: true, credentials: true })) // cookies SameSite=None
...`

Impacto: Ações não autorizadas em nome do usuário (CSRF).

Sugestão de correção: Restringir CORS a origem confiável, SameSite=Lax/Strict e validar Origin/CSRF token em mutações.

Critérios de aceite
- [] Requisição cross-origin sem token retorna 403
- [] cors() com origem permitida explícita

--- FIM ISSUE 16 ---

--- ISSUE 17 ---

[Segurança] Nome de arquivo enviado pelo usuário interpolado no caminho sem normalização nem validação de conteúdo.

Labels sugeridas: `security, severidade/alta`

Descrição do problema
Nome de arquivo enviado pelo usuário interpolado no caminho sem normalização nem validação de conteúdo.

Por que é explorável: originalname pode conter ../../ e sobrescrever arquivos arbitrários (path traversal / zip-slip).

Evidência
- `apps/api/src/routes/import.ts:60`
...
const dest = path.join(UPLOAD_DIR, file.originalname);
...`

Impacto: Escrita arbitrária no servidor; potencial RCE via configuração sobrescrita.

Sugestão de correção: Gerar nome aleatório, validar tipo por conteúdo (sniffing), limite de tamanho e armazenar fora da raiz pública.

Critérios de aceite
- [] Upload com ../../ não escreve fora do diretório
- [] HTML/SVG com script rejeitado

--- FIM ISSUE 17 ---

--- ISSUE 18 ---

[Segurança] Endpoints de login/reset sem rate limiting no código (depende de nginx com limite fixo não documentado).

****Labels sugeridas:**** `security, severidade/alta`

****Descrição do problema****

Endpoints de login/reset sem rate limiting no código (depende de nginx com limite fixo não documentado).

****Por que é explorável:**** A categoria 12 (token de reset) é brutável e credenciais podem ser testadas em massa.

****Evidência****

- `apps/api/src/routes/auth.ts:12`

...

router.post('/login', loginHandler) // sem rate limit no app

...

****Impacto:**** Brute force e credential stuffing contra contas.

****Sugestão de correção:**** Rate limit por IP e por conta com backoff exponencial; lockout temporário.

****Critérios de aceite****

- [] 10 falhas de login por conta/IP bloqueiam por 15 min
- [] Teste automatizado de rate limit

--- FIM ISSUE 18 ---

--- ISSUE 19 ---

[Segurança] Dependência com CVE alcançável e imagem base sem pin, ambas além da política de EOL.

****Labels sugeridas:**** `security, severidade/média`

****Descrição do problema****

Dependência com CVE alcançável e imagem base sem pin, ambas além da política de EOL.

****Por que é explorável:**** next@13.4.19 possui CVE conhecida; FROM node:18 sem tag específica instala versões imprevisíveis.

****Evidência****

- `package.json:45`

...

"next": "13.4.19" // CVE-2023-44487 (HTTP/2 DoS); Dockerfile: FROM node:18 (latest)

...

****Impacto:**** DoS e builds não reproduzíveis com superfície de vulnerabilidades desconhecida.

****Sugestão de correção:**** Atualizar dependências, pin de imagem base com digest, habilitar Dependabot/CI de auditoria.

****Critérios de aceite****

- [] npm audit sem críticas
- [] Imagem base com digest fixado

--- FIM ISSUE 19 ---

--- ISSUE 20 ---

[Segurança] Bucket S3 de exportações criado com ACL pública.

****Labels sugeridas:**** `security, severidade/alta`

****Descrição do problema****

Bucket S3 de exportações criado com ACL pública.

****Por que é explorável:**** Exportações contêm PII (relatório CSV, categoria 1) e ficam legíveis publicamente.

****Evidência****

- `terraform/main.tf:22`

...

acl = "public-read" # bucket de exportacoes

...

****Impacto:**** Vazamento público de dados de clientes.

****Sugestão de correção:**** Remover ACL pública, usar private + bucket policy restrita, verificar com checkov no CI.

****Critérios de aceite****

- [] Bucket sem ACL pública
- [] checkov limpo para o módulo de storage

--- FIM ISSUE 20 ---

--- ISSUE 21 ---

[Segurança] Stack trace completo em respostas de erro em produção e ausência de headers de segurança (CSP, HSTS).

```
**Labels sugeridas:** `security, severidade/média`

**Descrição do problema**
Stack trace completo em respostas de erro em produção e ausência de headers de segurança (CSP, HSTS).

**Por que é explorável:** Detalhes internos e versões auxiliam atacantes; sem CSP o XSS da categoria 5 amplifica.

**Evidência**
- `apps/api/src/app.ts:10`
...
app.use((err, req, res, next) => res.status(500).json({ error: err.stack })) // + sem helmet
...

**Impacto:** Reconhecimento facilitado e mitigação de XSS prejudicada.

**Sugestão de correção:** Erros genéricos em produção, helmet/secureHeaders com CSP e HSTS.

**Critérios de aceite**
- [ ] Resposta 500 não contém stack
- [ ] Headers de segurança presentes

--- FIM ISSUE 21 ---

--- ISSUE 22 ---

## [Privacidade/RGPD] 'Excluir conta' só marca deletedAt

**Labels sugeridas:** `security, severidade/alta, privacy`

**Descrição do problema**
'Excluir conta' só marca deletedAt: notas, activity, backups e logs continuam armazenando dados pessoais.

**Por que é explorável:** RGPD Art. 17 exige apagamento efetivo; soft-delete não atende ao direito ao esquecimento.

**Evidência**
- `apps/api/src/routes/users.ts:77`
...
user.deletedAt = new Date(); // soft-delete apenas; notas/activity/backups ficam
...

**Impacto:** Direito de apagamento inaplicável; dados permanecem sob controle do controlador sem base.

**Sugestão de correção:** Apagar/anonimizar dados em cascata (tabelas, cache, logs, backups) ou anonimização irreversível.

**Critérios de aceite**
- [ ] Após exclusão, dados do usuário ausentes em todas as tabelas
- [ ] Backup restaurado não contém PII ativa

--- FIM ISSUE 22 ---

--- ISSUE 23 ---

## [Privacidade/RGPD] Política de privacidade desatualizada e contradiz o que o código realmente faz (terceiros reais).

**Labels sugeridas:** `security, severidade/baixa, privacy`

**Descrição do problema**
Política de privacidade desatualizada e contradiz o que o código realmente faz (terceiros reais).

**Por que é explorável:** Art. 12-13 exigem informação precisa; inconsistência gera risco de enforcement e dano reputacional.

**Evidência**
- `apps/web/src/app/privacy/page.tsx:3`
...
'Não compartilhamos dados com terceiros' // contradiz PostHog/Sentry/Resend
...

**Impacto:** Informação enganosa ao titular; sanção por transparência.

**Sugestão de correção:** Revisar política com inventário real de dados, finalidades, terceiros e direitos.

**Critérios de aceite**
- [ ] Política lista todos os processadores reais
- [ ] Data de revisão atualizada

--- FIM ISSUE 23 ---

--- ISSUE 24 ---

## [Privacidade/RGPD] Coleta de dados sensíveis (saúde) como dado comum, sem consentimento explícito nem finalidade específica.

**Labels sugeridas:** `security, severidade/alta, privacy`

**Descrição do problema**
Coleta de dados sensíveis (saúde) como dado comum, sem consentimento explícito nem finalidade específica.
```

```
**Por que é explorável:** Art. 9 proíbe tratamento de categorias especiais sem base própria; falha gera multa máxima.

**Evidência**
- `apps/web/src/components/forms/HealthForm.tsx:7`
...
// coleta condicoes de saude sem base legal especifica (Art. 9)
...

**Impacto:** Tratamento ilícito de dados sensíveis; alto risco a direitos fundamentais.

**Sugestão de correção:** Consentimento explícito e destacado, minimização, DPIA e armazenamento com proteção adicional.

**Critérios de aceite**
- [ ] Campo de saúde bloqueado sem consentimento explícito
- [ ] DPIA documentada para o módulo

--- FIM ISSUE 24 ---

--- ISSUE 25 ---

## [Privacidade/RGPD] Pontuação de crédito/risco gerada por modelo sem fluxo de intervenção humana, explicação ou revisão.

**Labels sugeridas:** `security, severidade/média, privacy`

**Descrição do problema**
Pontuação de crédito/risco gerada por modelo sem fluxo de intervenção humana, explicação ou revisão.

**Por que é explorável:** Art. 22: decisão automatizada com efeitos significativos exige direito à intervenção humana e explicação.

**Evidência**
- `apps/api/src/services/score.ts:22`
...
score = model.predict(features(user)) // decisao automatizada sem revisao humana
...

**Impacto:** Titulares sem recurso efetivo contra decisões automatizadas.

**Sugestão de correção:** Prever endpoint de revisão humana, explicação e contestação da decisão.

**Critérios de aceite**
- [ ] Titular pode solicitar revisão humana
- [ ] Decisão expõe explicação ao titular

--- FIM ISSUE 25 ---
```

Anexos

Anexo 1 - Matriz de cobertura (categoria 3 / IDOR)

Rota	Método	Recurso	Posse	Evidência
/api/notes	GET	spaceId (implicit)	NÃO	notes.ts:42 (F1)
/api/notes/:id	DELETE	id	NÃO	notes.ts:66 (F4)
/api/teams/:id	GET	id	SIM	middleware/team.ts:31
/api/teams/:id/members	GET	teamId	NÃO	team.ts:55 (F5)
/api/teams/:id	DELETE	id	NÃO (RBAC)	team.ts:120 (F3)
/api/teams/export	GET	spaceIds[]	NÃO	team.ts:88 (F2)
/api/auth/login	POST	-	n.a.	auth.ts:12 (F16)
/api/users/me	DELETE	me	SIM	users.ts:77 (R2)

Anexo 2 - Matriz gate de UI ↔ endpoint (categoria 2)

Gate de UI	Arquivo	Endpoint	Backend valida?
isAdmin (DeleteTeamButton)	TeamSettings.tsx:15	DELETE /api/teams/:id	NÃO (F3)
isAdmin (TeamSettings menu)	TeamSettings.tsx:8	PUT /api/teams/:id	NÃO
isOwner (NoteMenu)	NoteMenu.tsx:20	DELETE /api/notes/:id	NÃO (F4)
role==='member' (view)	TeamPage.tsx:5	GET /api/teams/:id/members	NÃO (F5)

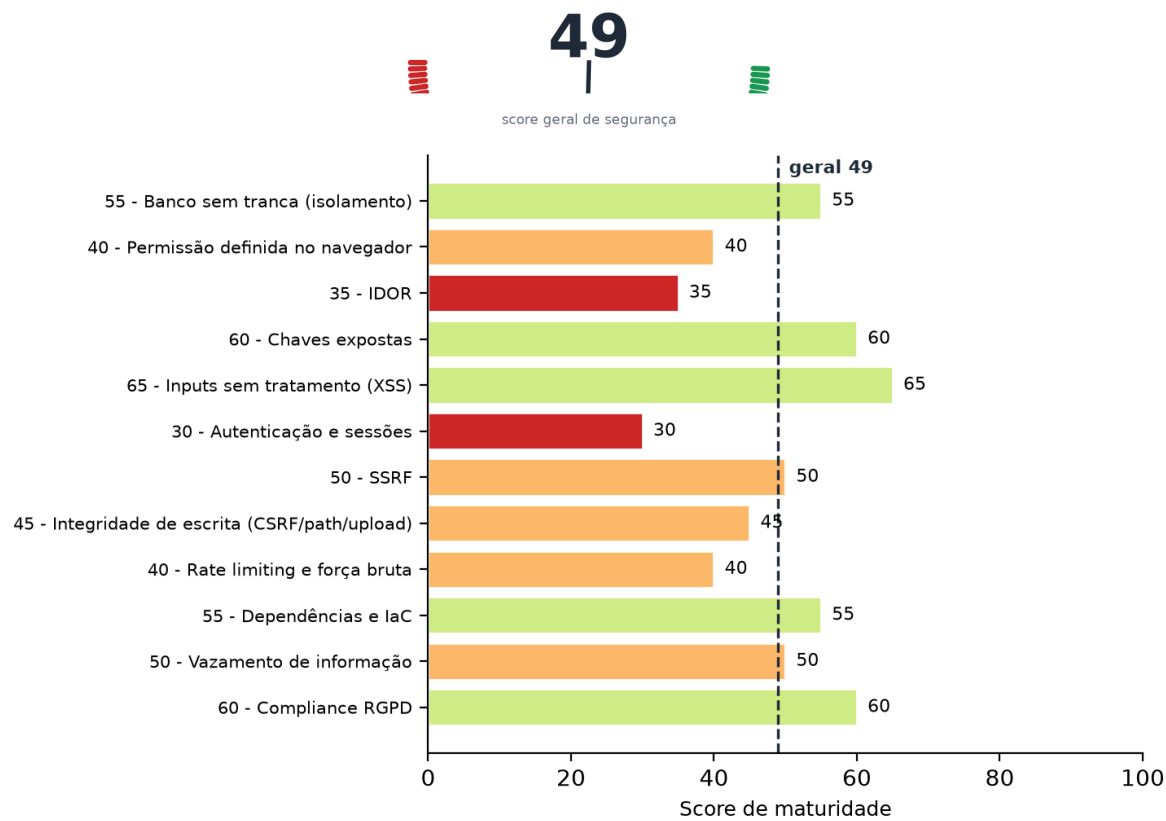
Anexo 3 - Resultados da Fase 0b (scans automatizados)

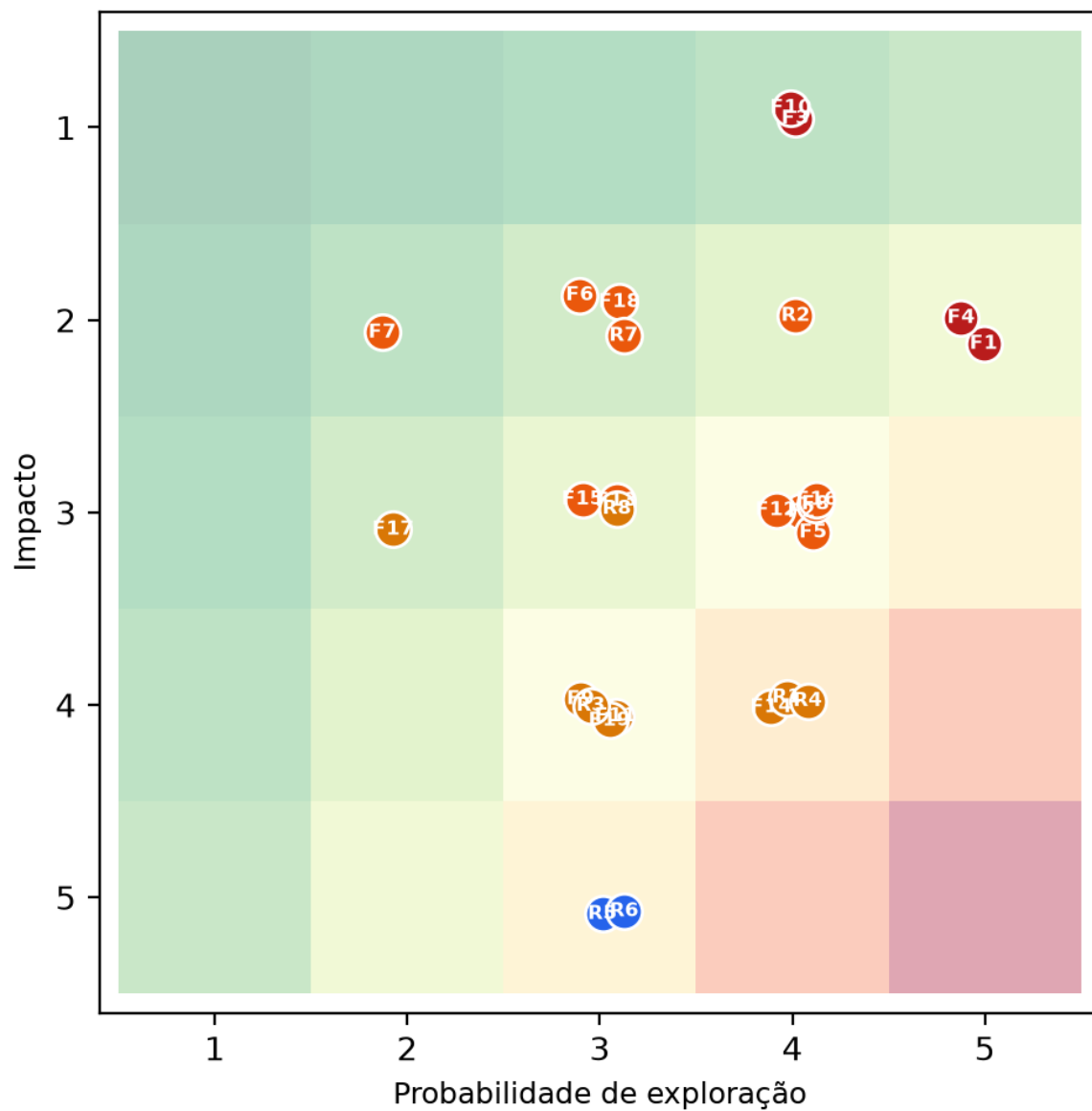
Ferramenta	Alvo	Alertas	Validados	Promovidos
gitleaks	git history	14	3	1 (F7)
npm audit	package-lock.json	5	2	1 (F17)
trivy	Dockerfile	8	2	1 (F17)
checkov	terraform/	6	2	1 (F18)
bundle scan	dist/	2	0	0

Anexo 4 - SBOM e processadores (categoria 12.7)

Componente	Versão	Status	DPA
next	13.4.19	CVE-2023-44487 (média)	-
express	4.18.2	Sem CVE crítica	-
argon2	não presente	SUBSTITUIR SHA-256 (F10)	-
imagem base node	18 (latest)	Sem pin/digest (F17)	-
PostHog	SDK web	Carregado sem consentimento (R4)	Sim
Sentry	SDK web	OK	Sim
Resend	e-mail transacional	Sem DPA assinado (12.7)	Não
Cloudflare	CDN	OK	Sim

Anexo 5 - Score de maturidade por categoria e heatmap de risco





Anexo 6 - Limites da auditoria

- Nenhum teste ativo de rede, força bruta ou exploração fora do ambiente local de desenvolvimento.
- Análise majoritariamente estática; PoCs de alta/crítica não executadas contra ambiente real.
- Não verificada a integridade de backups físicos (restauração) nem a configuração do provedor de e-mail.
- A superfície de terceiros (12.7) depende de DPA que não está no repositório.

Anexo 7 - Glossário (CWE e RGPD)

CWE-639	Autorização de acesso a recursos por ID não confiável (IDOR)
CWE-862	Autorização ausente
CWE-798	Uso de credenciais hardcoded
CWE-79	Cross-Site Scripting
CWE-916	Uso de hash fraco para senha
CWE-918	SSRF
CWE-352	CSRF
CWE-22	Path traversal
CWE-307	Restrição inadequada de tentativas
CWE-209	Exposição de informação sensível via mensagem de erro
CWE-359	Exposição de informação privada
RGPD Art. 7	Condições do consentimento
RGPD Art. 9	Dados sensíveis (categorias especiais)
RGPD Art. 17	Direito ao apagamento
RGPD Art. 22	Decisão automatizada
RGPD Art. 32	Segurança do tratamento
RGPD Art. 33-34	Notificação de violação

Lista de tarefas - acompanhamento

Use esta lista como base de acompanhamento, inclusive na versão impressa do relatório. Marque [x] quando a ação for concluída e preencha responsável, prazo e status. Os itens são os mesmos achados das seções anteriores, ordenados por prioridade (P1 = crítica, P2 = alta, P3 = média, P4 = baixa/informativa).

Feito	ID	Prio	Categoria	Ação	Responsável	Prazo	Status
[]	F1	P1	Isolamento	Listagem de notas não filtra por spaceId/usuário (apps/api/src/routes/notes.ts:42)			
[]	F3	P1	Permissão UI	O botão de excluir time fica escondido para não-admins na UI, mas DELETE /api/teams/ (apps/web/src/pages/settings/TeamSettings.tsx:15)			
[]	F4	P1	IDOR	Exclusão de nota por ID sem verificar se a nota pertence ao usuário/space do chamador. (apps/api/src/routes/notes.ts:66)			
[]	F10	P1	Auth	Senhas armazenadas com SHA-256 simples, sem salt e sem algoritmo de derivação lento. (apps/api/src/lib/password.ts:8)			
[]	F2	P2	Isolamento	Exportação CSV de atividade agrega registros de todos os tenants sem WHERE por inquilino. (apps/api/src/routes/team.ts:88)			
[]	F5	P2	IDOR	Lista de membros de um time sem validar que o chamador pertence ao time. (apps/api/src/routes/team.ts:55)			
[]	F6	P2	Chaves	Segredo de assinatura JWT com default público e sem validação de startup que rejeite o default. (docker-compose.yml:12)			
[]	F7	P2	Chaves	Chave real de produção commitada em .env e removida depois; ainda acessível no git history. (apps/api/.env (git history, commit a1b2c3d):1)			
[]	F8	P2	XSS	Conteúdo de nota (HTML do usuário) renderizado sem sanitização apesar de DOMPurify estar no package.json. (apps/web/src/components/NoteContent.tsx:9)			
[]	F12	P2	Auth	Token de reset de senha numérico de 6 dígitos sem tentativa de limite/rate limit. (apps/api/src/routes/auth.ts:120)			
[]	F13	P2	SSRF	URL de usuário buscada pelo servidor (preview de link) sem allowlist/denylst de hosts, sem bloqueio de IP interno e seguindo redirects. (apps/api/src/services/import.ts:33)			

Feito	ID	Prio	Categoria	Ação	Responsável	Prazo	Status
[]	F15	P2	Escrita	Nome de arquivo enviado pelo usuário interpolado no caminho sem normalização nem validação de conteúdo. (apps/api/src/routes/import.ts:60)			
[]	F16	P2	Rate lim.	Endpoints de login/reset sem rate limiting no código (depende de nginx com limite fixo não documentado). (apps/api/src/routes/auth.ts:12)			
[]	F18	P2	Dep./IaC	Bucket S3 de exportações criado com ACL pública. (terraform/main.tf:22)			
[]	R2	P2	RGPD	'Excluir conta' só marca deletedAt (apps/api/src/routes/users.ts:77)			
[]	R7	P2	RGPD	Coleta de dados sensíveis (saúde) como dado comum, sem consentimento explícito nem finalidade específica. (apps/web/src/components/forms/HealthForm.tsx:7)			
[]	F9	P3	XSS	Nome do usuário interpolado em e-mail HTML sem escape/espço. (apps/api/src/services/mailer.ts:31)			
[]	F11	P3	Auth	Login de administradores sem exigência de segundo fator. (apps/api/src/routes/auth.ts:40)			
[]	F14	P3	Escrita	Cookies de API com SameSite=None e mutações sem token CSRF nem verificação de Origin. (apps/api/src/routes/webhook.ts:19)			
[]	F17	P3	Dep./IaC	Dependência com CVE alcançável e imagem base sem pin, ambas além da política de EOL. (package.json:45)			
[]	F19	P3	Disclosure	Stack trace completo em respostas de erro em produção e ausência de headers de segurança (CSP, HSTS). (apps/api/src/app.ts:10)			
[]	R1	P3	RGPD	Checkbox de marketing pré-marcada e sem registro de consentimento (timestamp, versão, finalidade). (apps/web/src/components/forms/SignupForm.tsx:12)			
[]	R3	P3	RGPD	Logs registram corpo completo de requisições contendo e-mail/CPF, sem expiração. (apps/api/src/middleware/logger.ts:9)			
[]	R4	P3	RGPD	Script de analytics (PostHog) carregado na primeira página sem banner/consentimento prévio. (apps/web/src/lib/analytics.ts:5)			

Feito	ID	Prio	Categoria	Ação	Responsável	Prazo	Status
[]	R8	P3	RGPD	Pontuação de crédito/risco gerada por modelo sem fluxo de intervenção humana, explicação ou revisão. (apps/api/src/services/score.ts:22)			
[]	R5	P4	RGPD	Política de retenção documentada, mas nenhum job de expurgo/expiração implementado. (apps/api/src/lib/expunge.ts:1)			
[]	R6	P4	RGPD	Política de privacidade desatualizada e contradiz o que o código realmente faz (terceiros reais). (apps/web/src/app/privacy/page.tsx:3)			

Como usar

- Atribua cada item a um responsável e a uma data-alvo nos campos em branco.
- Ao concluir, marque [x] na coluna 'Feito' e anote a data de resolução em 'Status'.
- Acompanhe os itens P1 e P2 semanalmente; os demais podem entrar no backlog.
- Reexecute a auditoria e compare com esta lista para medir o progresso.